# ShelfLend

A library lending system, shipped the DevSecOps way

Parth Agarwal · Roll No. 10293 · Session 21 Final Capstone

github.com/Jadooonum1/devsecops-python

# Lending rules a real library desk needs

1

## A copy can't be lent twice

Row locks plus a partial unique index on active loans; the second request gets 409.

2

## Members have loan limits

Each member has max_loans (default 3); over the limit returns 409 with the count.

3

## Overdue loans earn fines

₹10 per late day on return; ₹100 unpaid blocks new loans until settled.

4

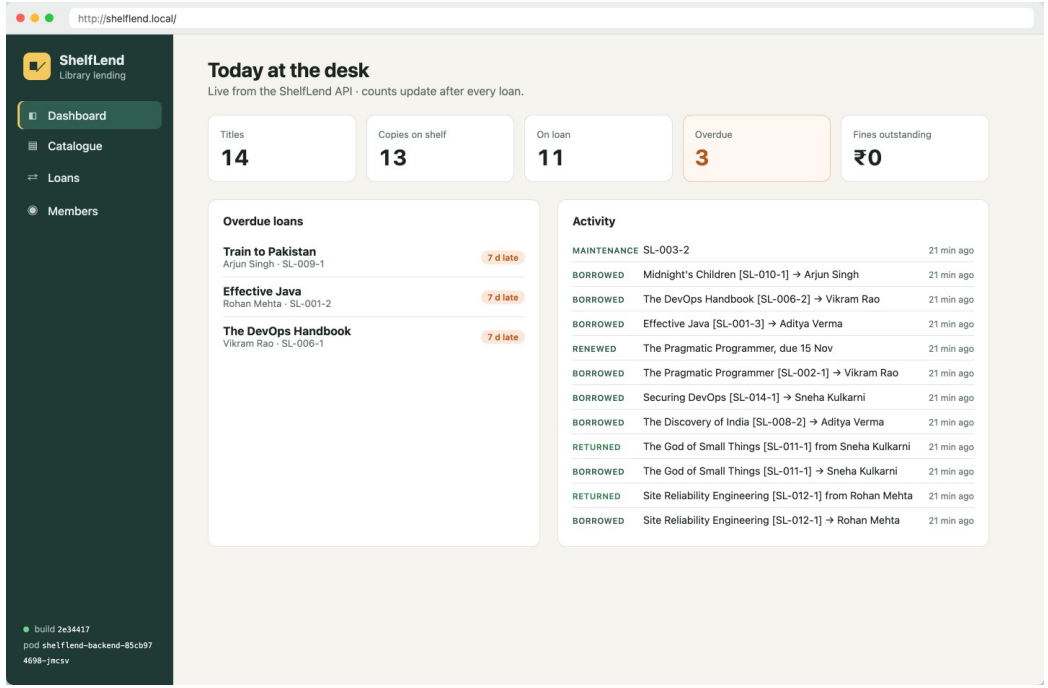
## Renewals are capped

Up to 2 renewals of 14 days, never on an overdue loan.

5

## Every change is audited

audit_events feeds the dashboard's activity stream.




*Dashboard served through the Kubernetes Ingress*

# Tech stack

## Application

FastAPI 0.142 · SQLAlchemy 2.0 · Alembic 1.20

React 18 + Vite 6 · PostgreSQL 17

## Quality

pytest 9 (32 tests, 92% coverage)

SQLite test DB built by real migrations

## Containers

python:3.12-slim multi-stage (UID 10001)

node:22 → nginx-unprivileged (UID 101)

## CI/CD + Security

GitHub Actions · GHCR (SHA tags, amd64+arm64)

Trivy 0.75 · Gitleaks 8.30 · Bandit 1.9

## Platform

kind 0.33 · Helm 4 · ingress-nginx 1.15

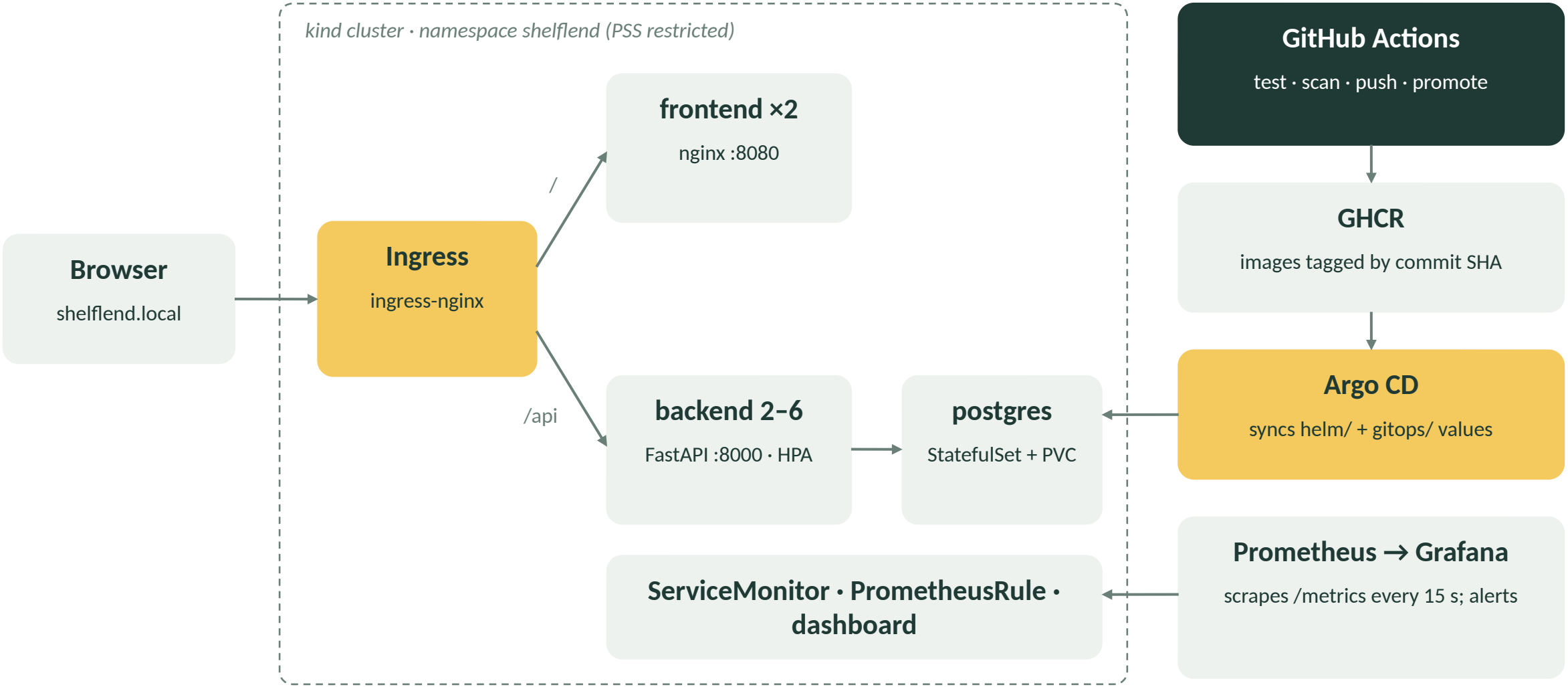
Argo CD 3.5 (GitOps) · HPA + PDB

## Infra + Observability

Terraform 1.16, AWS provider 6.x

kube-prometheus-stack 92.8 · Grafana

# Architecture



# One rule, three layers of defence

*“A copy can never be on two active loans”*

### 1 API check

copy.status must be available, else 409 "copy SL-001-1 is on loan"; the loan limit and fine block are checked the same way.

### 2 Row locks

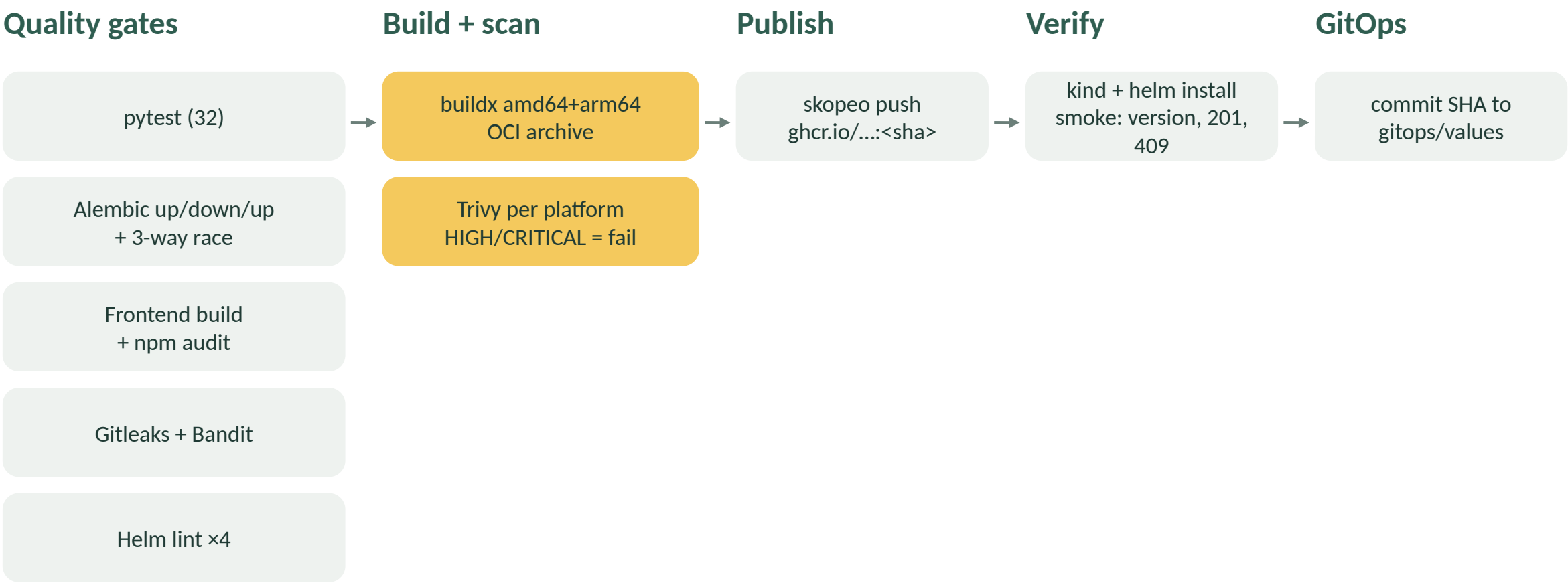
SELECT … FOR UPDATE on member and copy, so two backend replicas handling simultaneous requests are serialised.

### 3 Database

Partial unique index uq_loans_one_active_per_copy plus CHECK constraints on statuses, dates and fines. A test proves a raw INSERT is refused.

Migrations take a Postgres advisory lock: in a 3-pod race exactly one pod applied 0001/0002.

# CI/CD: every push to main, 11 jobs




**Scan what you ship:** the archive Trivy approved is the exact one pushed. No :latest tag, and a 'tag required' guard in the Helm chart. Least-privilege permissions per job; the promote commit is path-ignored so it can't loop.

# DevSecOps: Trivy blocked the first build

**7**

HIGH findings in the first backend image

**0**

after the fix, on amd64 and arm64, backend and frontend

Gate: severity HIGH,CRITICAL · exit-code 1 · ignore-unfixed (under vulnerability:) · Gitleaks over full history · Bandit -ll

Also removed unused nginx modules from the frontend image (libtiff / libxslt / geoip) before the first scan.

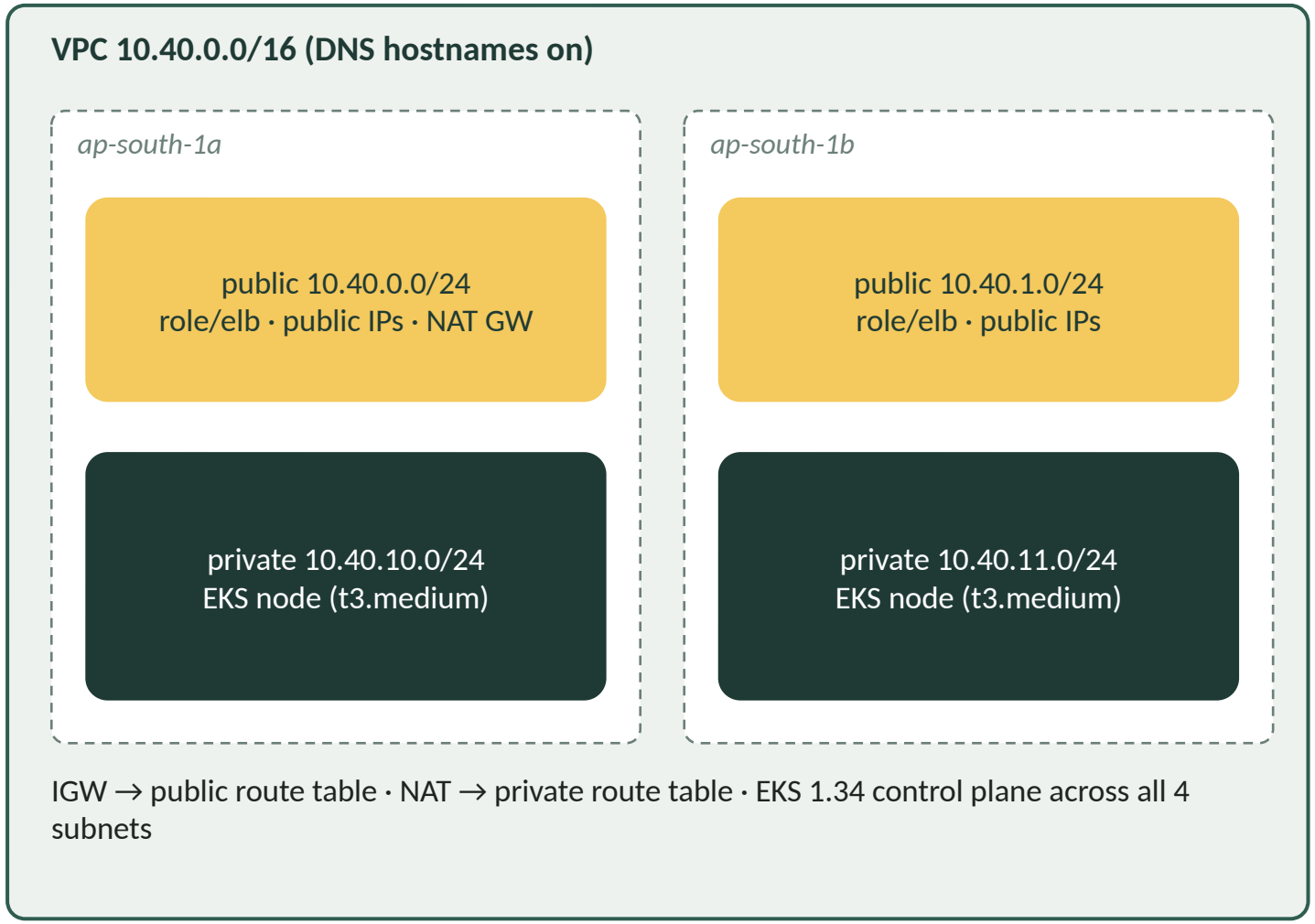
### CVE-2025-62727 · Starlette 0.48.0

**What:** a crafted Range header with many overlapping ranges made Starlette's merging step use excessive CPU, a denial-of-service. Fixed in 0.49.1.

**Also found:** two more Starlette advisories, setuptools (CVE-2025-47273), and urllib3 + msgpack vendored inside pip (CVE-2026-97687/97689, GHSA-6v7p-g79w-8964).

**Fix:** upgrade FastAPI/Starlette, and make the backend multi-stage so the runtime image has no pip or setuptools at all (that removes the vendored urllib3 and msgpack too). Trivy exit code 1 → 0.

# Terraform: VPC + EKS in ap-south-1




**22** plain aws_* resources, no modules

**4** subnets over 2 AZs (2 public)

**2** managed nodes (min 1, max 3)

Run against the moto AWS emulator (no AWS account): init → plan (22 to add) → apply → destroy (22 destroyed). Same .tf files; only a git-ignored provider override differs.

# Kubernetes + GitOps loop

git push

↓

pipeline green

↓

promote commit
(SHA → gitops/)

↓

**Argo CD sync**
**(≤ 60 s poll)**

↓

rolling update
maxUnavailable 0

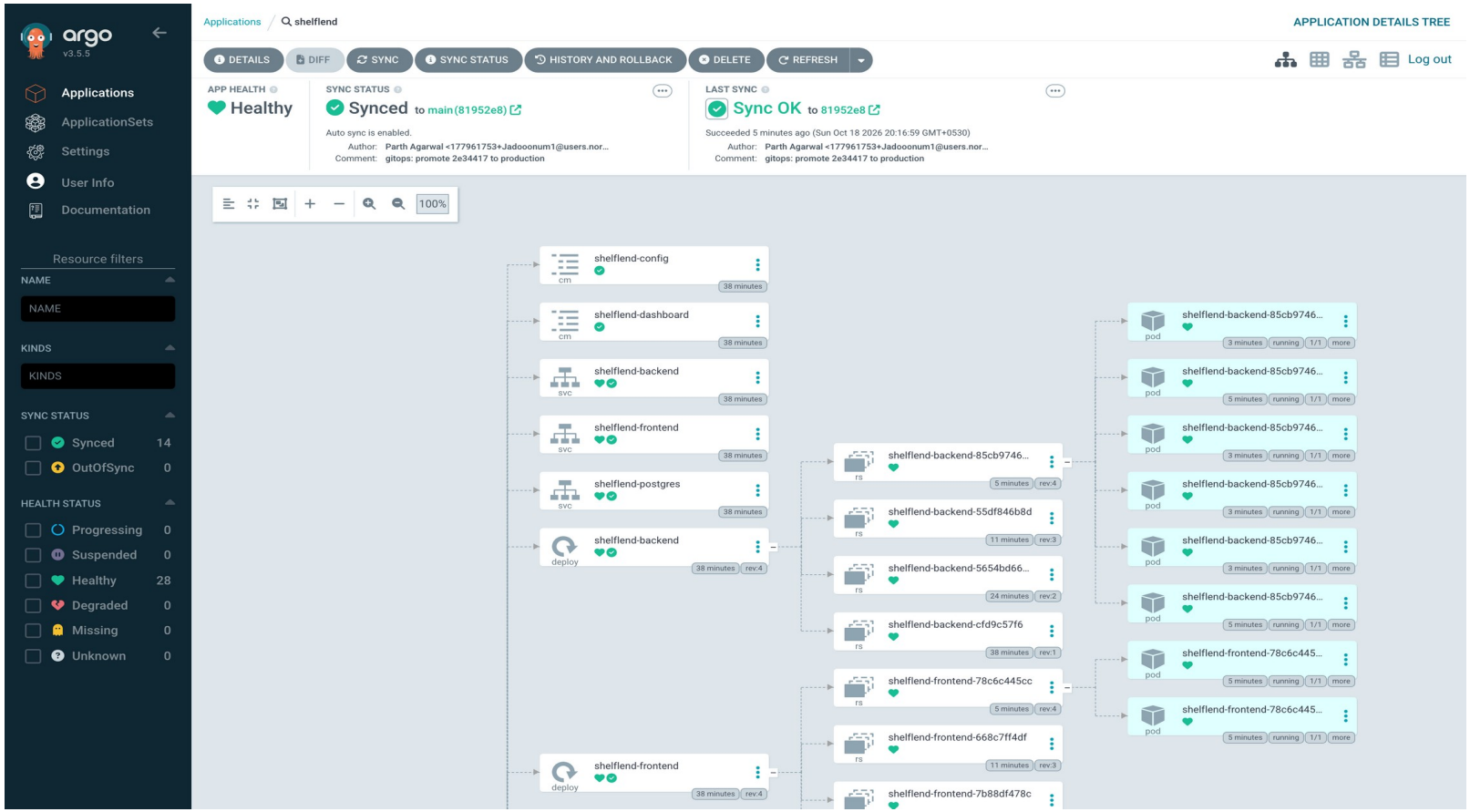
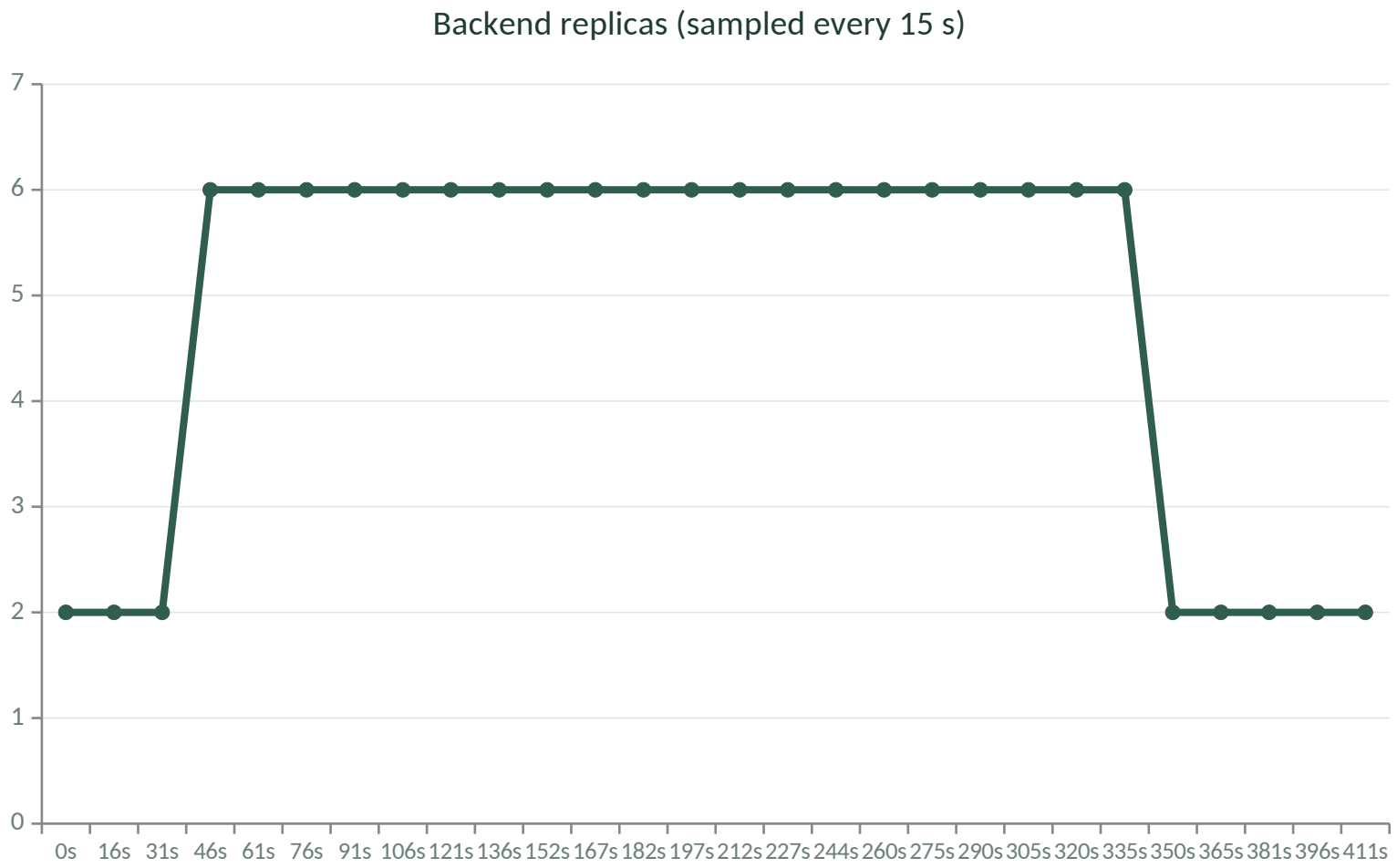



Chart: required SHA tag · non-root, read-only root FS, seccomp, drop ALL · HPA 2–6 @60% CPU · PDB minAvailable 1 · Ingress / → frontend, /api → backend

# Load test: the HPA scales 2 → 6 and back




**6**

replicas at peak (max 6)

**396%**

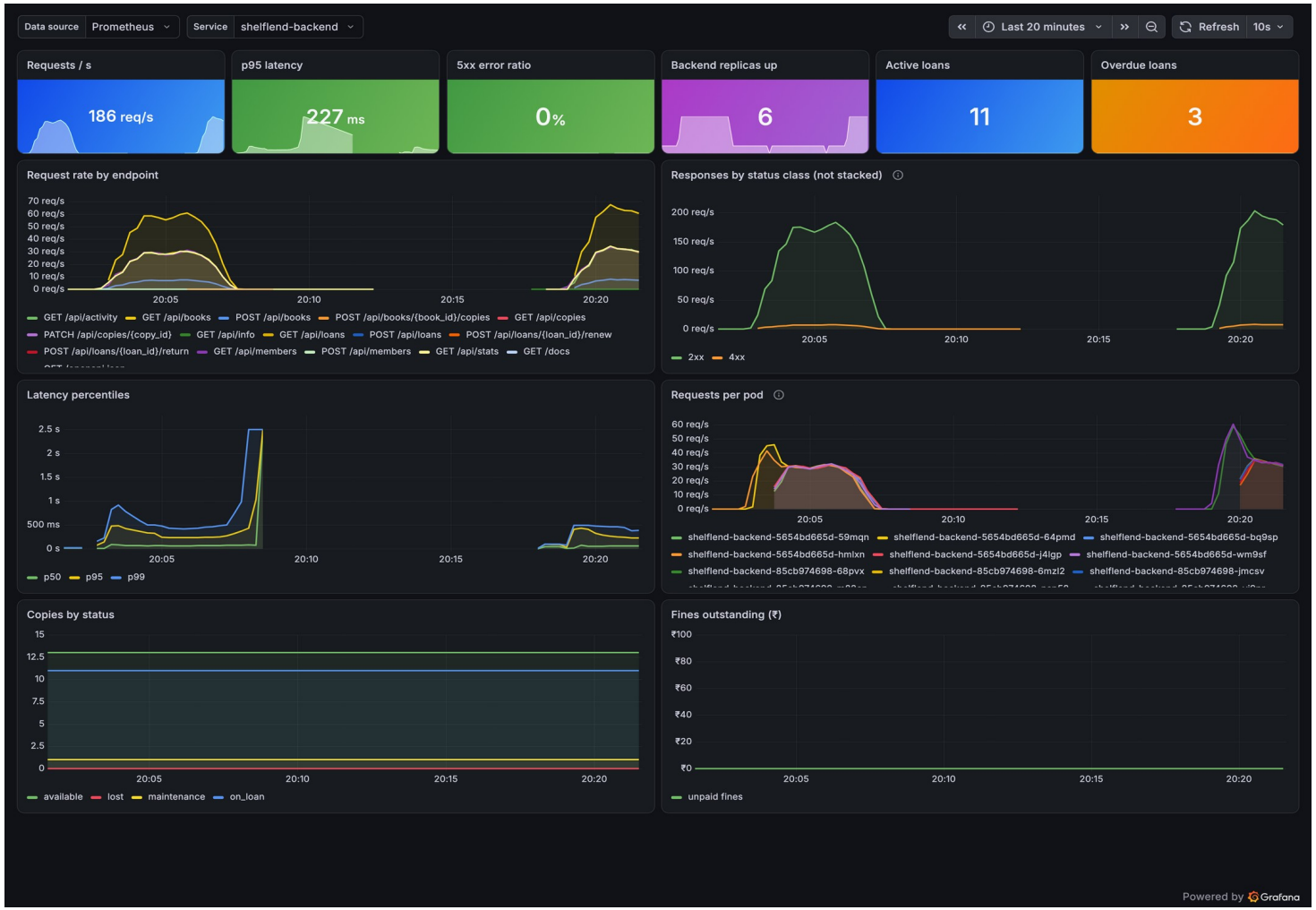
peak avg CPU vs 60% target

**16**

curl workers × 4 min via Ingress

scaleDown stabilisation window 60 s; Prometheus showed 6/6 targets UP during the run.

# Observability: HTTP and business metrics




## /metrics

prometheus-fastapi-instrumentator, latency buckets from 5 ms

## Business gauges

loans active/overdue, copies by status, fines, read from Postgres at scrape time

## ServiceMonitor

Prometheus scrapes every backend pod every 15 s

## 4 alert rules

BackendDown, 5xx > 5%, p95 > 500 ms, Overdue loans > 5

## Grafana

12-panel dashboard shipped in the Helm chart (sidecar label)

# Key learnings

### 1 Architecture is part of the artifact

The first GitOps sync crash-looped with 'exec format error': CI built amd64, the Mac runs arm64. Multi-arch images fixed it.

### 2 Scanners find real things

Trivy's first run failed on 7 HIGH findings; dropping pip from the runtime image removed a whole class of them.

### 3 Defaults hide data

Prometheus ignored the ServiceMonitor until the *SelectorNilUsesHelmValues flags were false; Grafana's 5xx stat read 'No data' instead of 0.

### 4 Argo CD isn't Helm

No lookup(), no Helm release: the DB secret is created at bootstrap and staging is Helm-installed for helm list.

# Known limitations

### Terraform ran on an emulator

No personal AWS account; plan/apply/destroy ran against moto. The rubric's AWS Console screenshots are replaced by AWS CLI output from the emulator.

### Single Postgres replica

A StatefulSet with one PVC, no backups or HA; production would use RDS.

### No authentication

The desk UI is open; a real deployment needs staff login and role checks.

### Local cluster only

Kubernetes ran on kind; the chart is EKS-ready (Ingress, resources, PDB) but not deployed there.

# Thank you

Parth Agarwal · Roll No. 10293

Repo: github.com/Jadooonum1/devsecops-python

Images: ghcr.io/jadooonum1/shelflend-backend · shelflend-frontend

Demo video + slides: demo/